

מודול 15 — הנדסה חברתית ופישיוג — תרגול

חומר לימוד

1 יחידות

תוכן העניינים

1. 🧠 תרגול — מודול 15: הנדסה חברתית ופישנינג

תרגול — מודול 15: הנדסה חברתית ופשינג

חלק א' — שאלות תרגול (עם תשובות). חלק ב' — תרחיש מהחיים האמיתיים.

חלק א' — שאלות תרגול

- Q1. למה "האדם הוא החוליה החלשה ביותר"? מה אחוז הפריצות שמתחילות בפשינג?
- Q2. אילו שני עקרונות השפעה משולבים ברוב מיילי הפשינג המוצלחים?
- Q3. מה ההבדל בין Spear Phishing ל-Whaling?
- Q4. מהו Pretexting? תן דוגמה.
- Q5. איך OSINT הופך ספיר-פשינג ליעיל יותר?
- Q6. מה עושה GoPhish, ואילו מדדים הוא מספק?
- Q7. איך evilginx עוקף MFA?
- Q8. מהו הכלל האתי המרכזי בהצגת תוצאות סימולציית פשינג?

תשובות

- אפשר להקשיח טכנולוגיה אך קשה להקשיח אנשים; ~90% מהפריצות מתחילות בפשינג.
- סמכות + דחיפות** (למשל "IT — אפס סיסמה תוך 24 שעות").
- Spear Phishing = ממוקד לאדם ספציפי; Whaling = ספיר-פשינג ל**בכיר** (מנכ"ל/סמנכ"ל).
- בניית **תרחיש כיסוי** אמין לפני הבקשה; למשל "אני הטכנאי החדש, צריך את הסיסמה לבדיקה".
- מידע (תפקיד, פרויקטים, קולגות) הופך את המייל למוטאם ואמין → שיעורי לחיצה גבוהים בהרבה.
- Framework לקמפיין פשינג מבוקר; מדדים: אחוז פתיחה, לחיצה, ומסירת פרטים.
- reverse proxy שגונב את ה-**session cookie** אחרי אימות מוצלח → כניסה ללא MFA נוסף.
- דיווח מרוכז ללא שמות** — אחוזים בלבד; המטרה חינוך ולא שיימינג/ענישה.

חלק ב' — תרחיש מהחיים האמיתי

“מהמייל אל ה-Domain” 🧐

בבדיקת PNPT (בהרשאה מלאה), התחלת ללא גישה פנימית כלל. המטרה: דריסת רגל ברשת דרך הגורם האנושי.

1. OSINT → theHarvester + LinkedIn: 40 עובדים, מבנה מייל 365. Office: טכנולוגיה, first.last@corp.com.
2. Pretext → "חדש, התחבר לאימות Office 365-מעבר ל: IT מחלקת".
3. GoPhish → Landing Page שבת של דף התחברות 0365.
4. שליחה → 40 עובדים; 14 לחצו, 6 הזינו סיסמה.
5. → רגל בדלת → VPN-גישה → אחת הסיסמאות עבדה ב. (מודול 13) AD ו-Kerberoasting משם.

המשימה: 1. מדוע שלב ה-OSINT היה **קריטי** להצלחת הקמפיין? 2. אילו **שתי** הגנות טכניות היו מפחיתות משמעותית את הנזק בשלב 5? 3. כיצד תציג את התוצאה (6 עובדים מסרו סיסמה) בדוח **מבלי לפגוע** בהם?

פתרון מנחה 💡

1. OSINT חשף את **מבנה המיילים, שמות העובדים והטכנולוגיה (O365)** — בלעדיו לא היינו יכולים לבנות דף נחיתה משכנע או לדעת למי לשלוח. הוא הבסיס לכל ספיר-פישנינג.
2. **MFA** (א) — גם עם סיסמה נכונה, ה-VPN היה חוסם ללא הגורם השני; (ב) **סינון מייל (DMARC/אנטי-פישנינג)** — חלק מהמיילים היו נחסמים לפני שהגיעו.
3. מדווחים **אחוז** (15% מסרו פרטים) ולא שמות; ממסגרים כ"הזדמנות להדרכה" ומציעים תוכנית מודעות — לעולם לא רשימת "נכשלים".

🎯 שרשרת "פישנינג → סיסמה → AD → VPN" היא איך פריצות אמיתיות באמת קורות. הגורם האנושי הוא לרוב הכניסה הקלה ביותר — ולכן הדרכה + MFA הם ההגנה החשובה ביותר.

← חזרה למודול · תרגילים מעשיים